

CVE Report — Dependency Scan

Project: `vulnerable-invoice-service` · Stage 1 (OWASP Dependency-Check + Maven) → Stage 3 (Auto-Remediation) · Generated 2026-07-10
· Source: `pom.xml` @ `61ed8c3` → branch `fix/depSCAN-20260710-060240`

Summary — before this PR

Metric	Count
Total CVE instances found	86
CRITICAL instances	18
HIGH instances	48
MEDIUM instances	19
LOW instances	1
Outdated dependencies	8
License violations	1
License warnings	1
Supply-chain alerts	1 (typosquat) + 1 (untrusted mirror)

Summary — after this PR (re-scan via `mvn dependency:tree` + version cross-check)

Metric	Before	After	Change
CRITICAL instances	18	0	-18 (100% cleared)
HIGH instances	48	11	-37 (77% cleared)
MEDIUM instances	19	6	-13 (68% cleared)
LOW instances	1	0	-1 (100% cleared)
Typosquatted coordinate	1	0	removed
Untrusted HTTP mirror	1	0	removed
License violation (GPL-2.0)	1	1	unresolved — MAJOR_REVIEW

Remaining HIGH/MEDIUM instances after this PR are `mysql:mysql-connector-java:8.0.30` (2 CVEs, untouched — see MAJOR_REVIEW below), its transitive `com.google.protobuf:protobuf-java:3.19.4` (5 CVEs, tied to the same MAJOR_REVIEW), and 5 `log4j` CVEs (`CVE-2026-34477/34479/34480/34481` , `CVE-2025-68161`) whose scanner `fix_version` was recorded as the open-ended `"2.17.1+ (verify latest 2.x)"` rather than a concrete release — see **Not fully verified** below.

Fixes applied in this PR

Dependency	Old version	New version	CVEs cleared
------------	-------------	-------------	--------------

org.apache.logging.log4j:log4j-core	2.14.1	2.17.1	CVE-2021-44228 (10.0), CVE-2021-45046 (9.0), CVE-2021-44832 (6.6), CVE-2021-45105 (5.9)
org.apache.logging.log4j:log4j-api	2.14.1	2.17.1	CVE-2021-44228 (10.0), CVE-2021-45046 (9.0), CVE-2021-44832 (6.6), CVE-2021-45105 (5.9)
com.fasterxml.jackson.core:jackson-databind	2.9.8	2.9.10.8	56 CVEs (14 CRITICAL , 37 HIGH , 5 MEDIUM) incl. CVE-2019-14379, CVE-2019-14540, CVE-2019-16335, CVE-2019-16942/16943, CVE-2019-17267/17531, CVE-2019-20330 — 2.9.10.8 is FasterXML's final consolidated 2.9.x blacklist release; the vendor does not file new CVEs against 2.10+ for this class of issue
com.google.guava:guava	24.1.1-jre	32.0.0-jre	CVE-2023-2976 (5.5), CVE-2020-8908 (3.3)
commons-io:commons-io	2.4	2.14.0	CVE-2021-29425 (4.8), CVE-2024-47554 (4.3)
org.apache.commons:commons-lang3	3.4	3.18.0	CVE-2025-48924 (5.3)
com.fastxml.jackson.core:jackson-databind (typosquat)	2.9.8	removed	n/a — supply-chain removal, not a CVE
internal-untrusted-mirror (plaintext-HTTP repo)	present	removed	n/a — supply-chain removal

Not fixed in this PR (see follow-up items)

Dependency	Version	Top CVE	CVSS	Severity	Status
mysql:mysql-connector-java	8.0.30	CVE-2023-22102	8.3	HIGH	MAJOR_REVIEW — untouched
mysql:mysql-connector-java	8.0.30	CVE-2023-21971	5.3	MEDIUM	MAJOR_REVIEW — untouched
com.google.protobuf:protobuf-java (transitive via mysql)	3.19.4	CVE-2022-3509 / 3510 / 2024-7254 / 2026-0994	7.5	HIGH (x4)	tied to MAJOR_REVIEW above
com.google.protobuf:protobuf-java (transitive via mysql)	3.19.4	CVE-2022-3171	4.3	MEDIUM	tied to MAJOR_REVIEW above

Supply-chain alerts (resolved)

CRITICAL — Typosquatted dependency, REMOVED. `com.fastxml.jackson.core:jackson-databind:2.9.8` impersonated the legitimate `com.fasterxml.jackson.core`; the coordinate did not exist on Maven Central and always failed resolution. Deleted entirely — no safe version bump applies to a non-existent, malicious-pattern coordinate.

HIGH — Untrusted repository, REMOVED. `http://insecure-mirror.example.net/maven2` was a plain-HTTP Maven repository (MITM / dependency-confusion risk) configured alongside the typosquat above. Removed; only the trusted, HTTPS-served Maven Central repository remains.

Follow-up items (not auto-applied — human review required)

- MAJOR_REVIEW — `mysql:mysql-connector-java:8.0.30`** : carries a GPL-2.0-with-FOSS-exception license violation (Issue #3) in this permissive-license project, and CVE-2023-22102 / CVE-2023-21971 (vulnerable range extends through 8.1.0, so no same-coordinate patch clears it). The real fix — migrating to `com.mysql:mysql-connector-j ≥ 8.2.0` — clears the CVEs but keeps the **same GPL-2.0/commercial dual license**, so it would not resolve the flagged license violation. Per the remediation

skill, a change that leaves a denied license unchanged is not a safe auto-apply candidate. Left untouched; needs a human license/legal decision (swap driver, negotiate license exception, or replace with a permissively-licensed JDBC driver).

- **NEEDS_VERIFICATION (log4j)** — **CVE-2026-34477** , **CVE-2026-34479** , **CVE-2026-34480** , **CVE-2026-34481** , **CVE-2025-68161** : scanner recorded `fix_version` as the open-ended `"2.17.1+ (verify latest 2.x)"` rather than a concrete release. We bumped to exactly `2.17.1` (clears the well-known Log4Shell family: CVE-2021-44228/45046/44832/45105) but cannot confirm from this data whether 2.17.1 itself clears these five newer entries. Recommend confirming against the current log4j 2.x latest release and bumping further if required.

Machine-readable source: `depscan-report.json` . Generated by the *Dependency & Supply-Chain Plugin* — Stage 1 findings, Stage 3 remediation status.